

Improving Security and Performance of Financial RESTful APIs Using ChatGPT in ASP.NET Core

Zaw Ye Htut Ko | G6519692

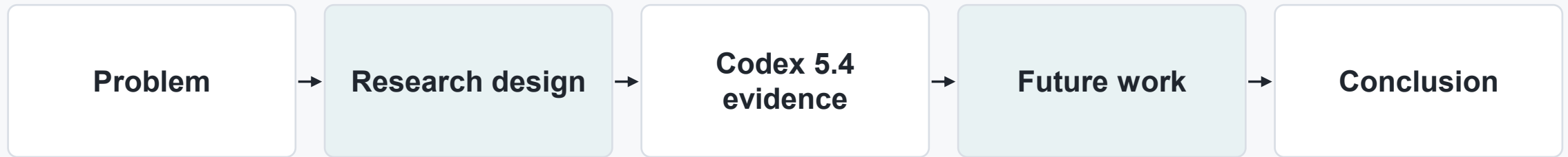
Master of Science in Information Technology
Advisor: Assistant Professor Dr. Darun Kesrarat

Primary evaluated model: ChatGPT/Codex 5.4

Evidence first

Model proposes.
Evidence decides.

Defense Roadmap



Problem -> controlled method -> Codex 5.4 results -> future-work follow-up -> conclusion

One API, Three Failure Modes

Security

Headers, dependencies,
authentication, authorization

Performance

Latency, throughput, errors,
stress recovery

Maintainability

Code smells, complexity,
duplication, quality gate

Research Gap

Dominant prior focus

Code generation

Completion accuracy

Developer productivity



This thesis

Tool findings as prompts

Branch-isolated fixes

Independent remeasurement

Research Questions

RQ1

Can tool-guided ChatGPT recommendations reduce measured code-quality findings without regression?

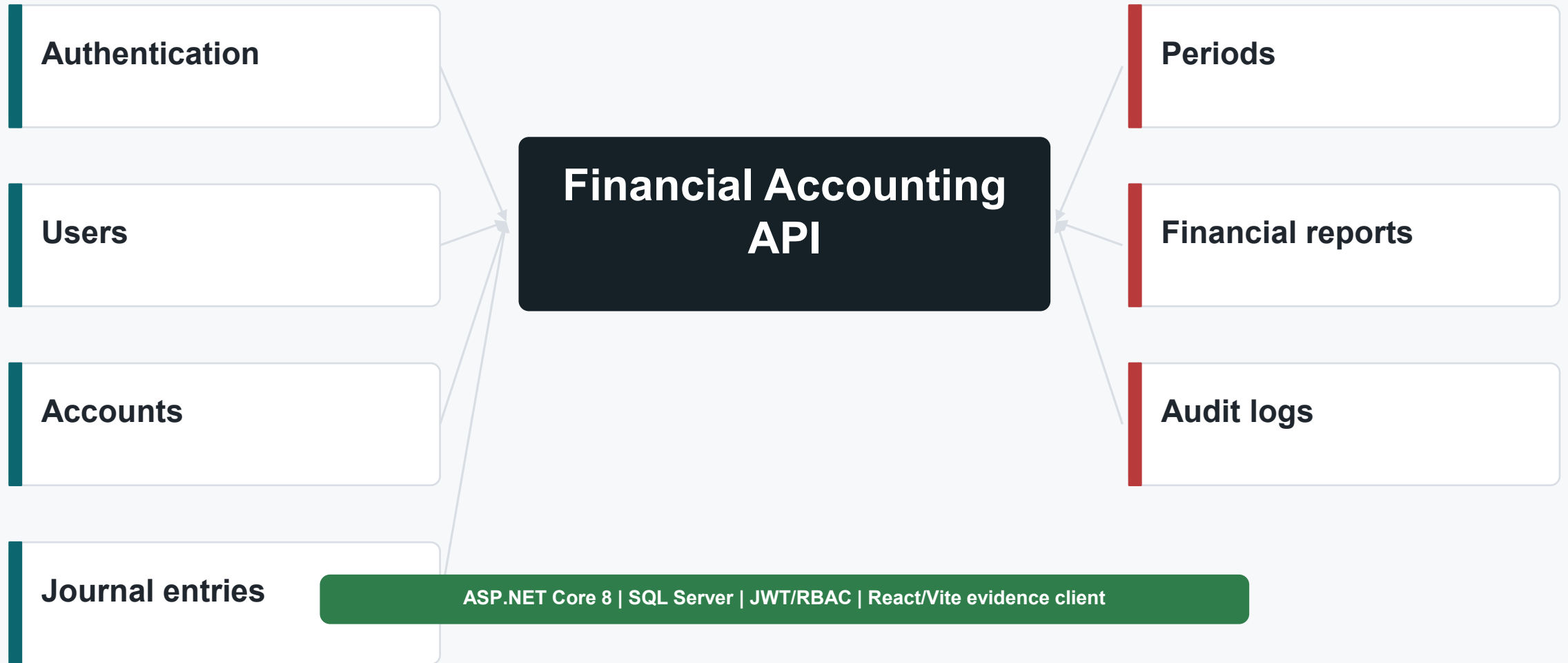
RQ2

Can they clear gated security alerts while preserving role-based access?

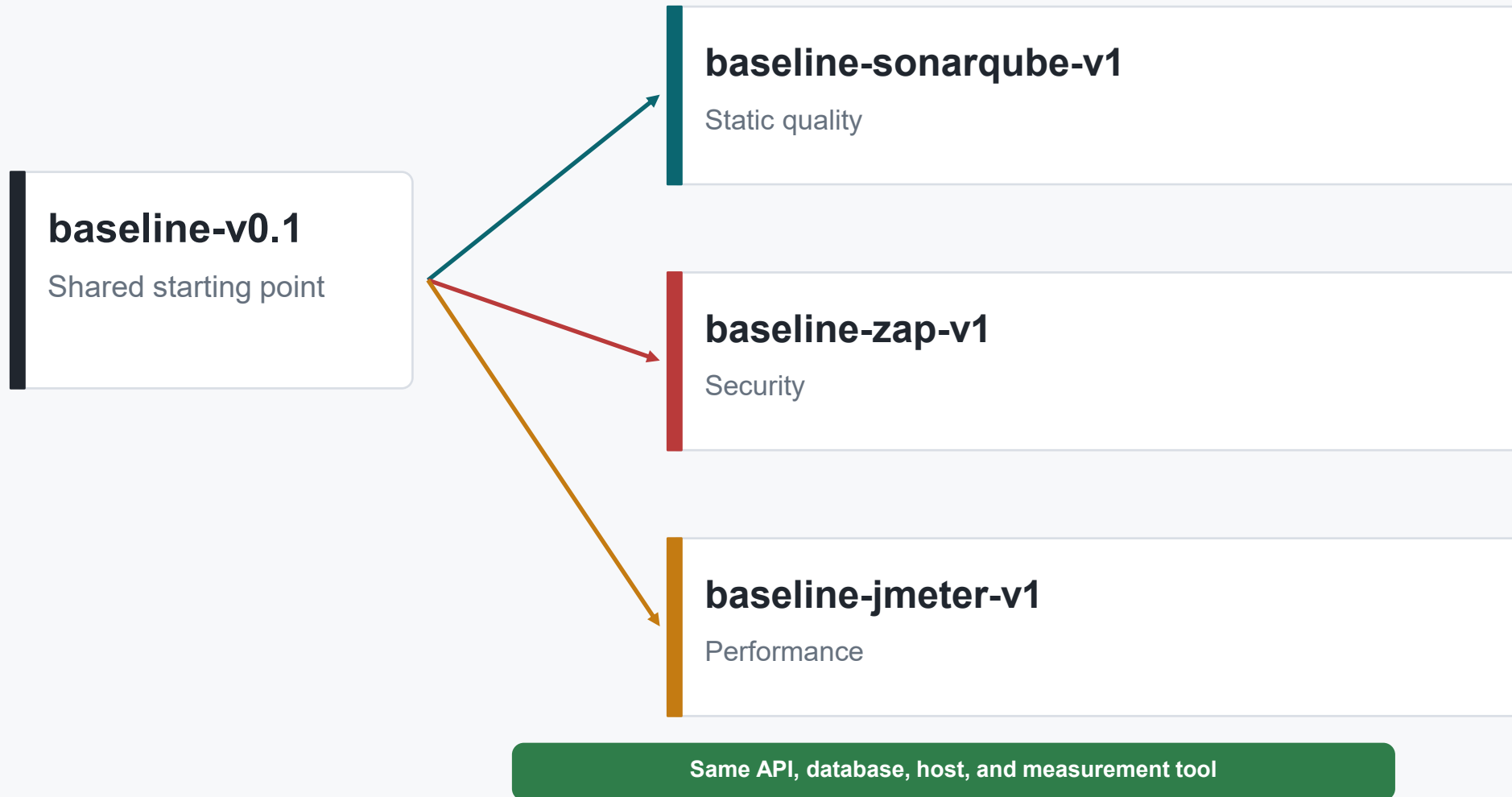
RQ3

Can they reduce tail latency and maintain zero-error behavior under load?

System Under Study



Branch-Isolated Research Design



Four-Phase Evidence Workflow

01 Capture baseline

Preserve raw tool findings and environment state

02 Propose bounded fix

Give the model the finding, source context, and constraints

03 Human review and tests

Protect authorization, accounting invariants, and contracts

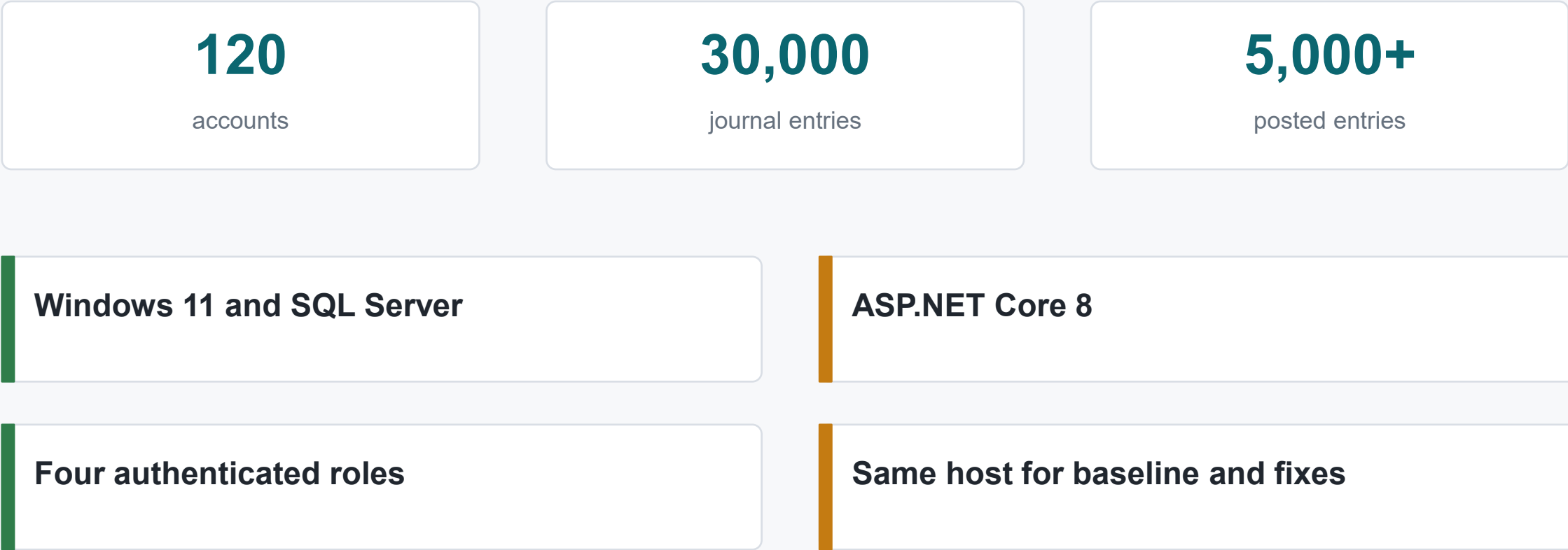
04 Rerun and compare

Accept only changes supported by the original measurement tool

Finding -> patch -> tests -> remeasurement



Environment and Seeded Dataset



Evaluation Gates

SonarQube

Static quality

OWASP ZAP

Security alerts

Apache JMeter

Load behavior

dotnet test

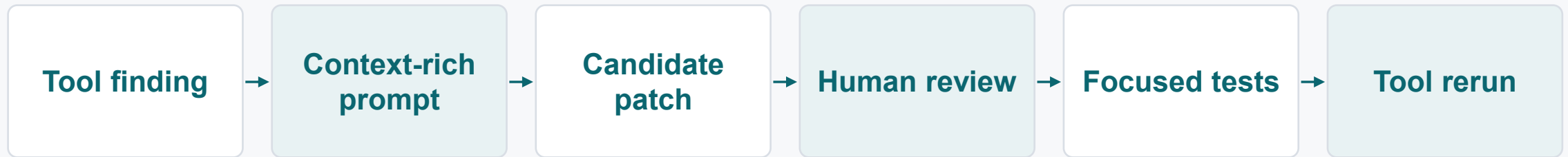
Regression
safety

Git evidence

Traceability

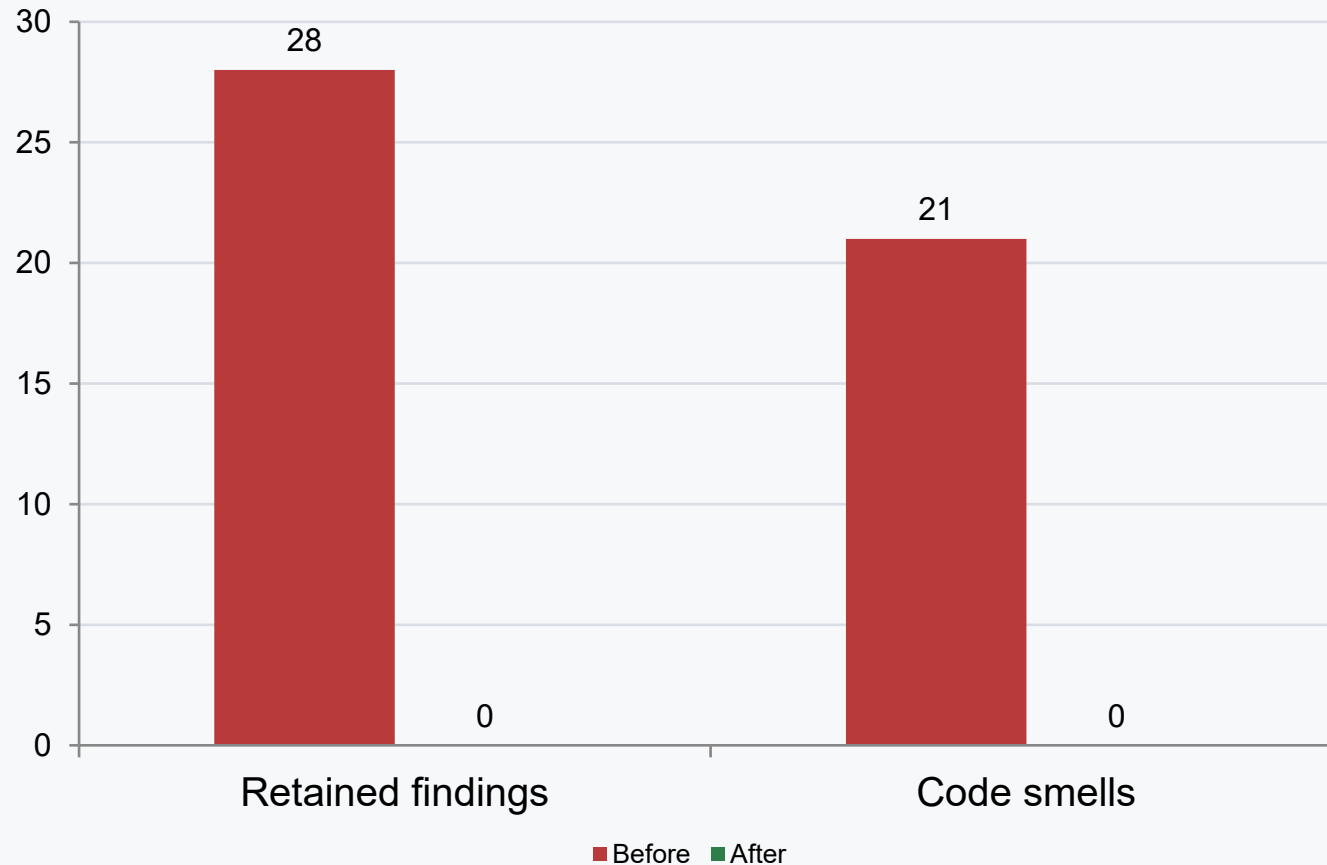
No single metric is overall quality

Human-in-the-Loop Use of ChatGPT/Codex



Acceptance is determined by evidence, not model confidence

SonarQube: Clean Closure Without Coverage Loss



Quality Gate: OK

Coverage: 74.3% -> 74.3%

Duplicated lines: 0.0% -> 0.0%

OWASP ZAP: Business-Endpoint Gates Cleared

Baseline scan

Medium 2 -> 0

Low 6 -> 0

Informational 3 -> 4

Authenticated API scan

Low 3 -> 0

Informational 5 -> 5

High 0 | Medium 0 | Low 0 after remediation

JMeter: Five Workload Profiles

p50

Normal load

p100

Higher concurrency

p500

Heavy concurrency

Soak

Sustained behavior

Spike

Burst and recovery

p95 and p99 latency



Throughput

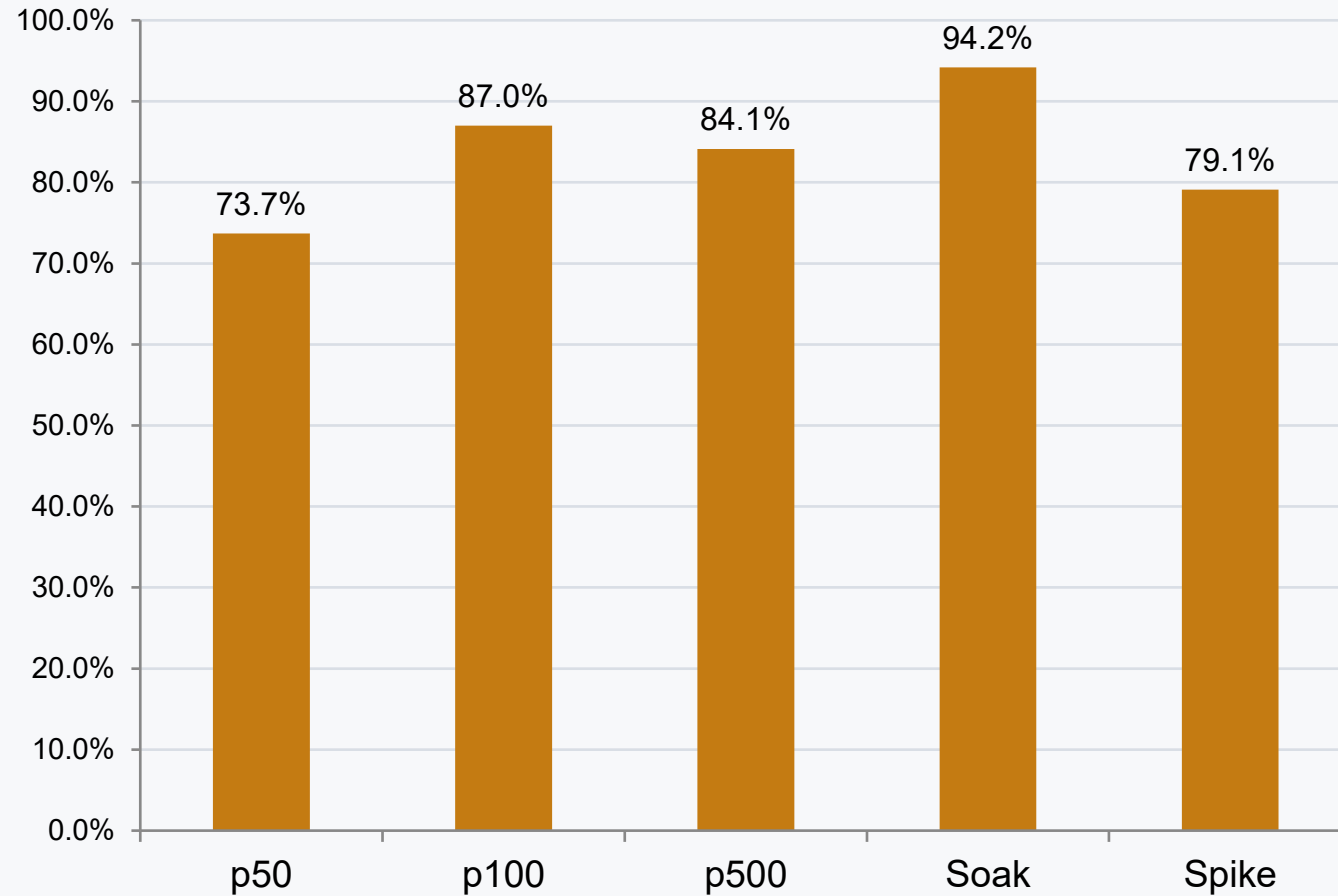


Error rate



Drift

JMeter: Large p95 Reductions, One Honest Caveat



Core reliability

0.00% error rate on p50, p100, and p500

Caveat retained

Mixed-workload soak/spike drift heuristics still fail

Integrity Was a Non-Negotiable Constraint

CHECK 01

JWT authentication

CHECK 02

Role-based authorization

CHECK 03

Balanced debit and credit

CHECK 04

Accounting-period rules

CHECK 05

Idempotency and concurrency

CHECK 06

Audit writes

CHECK 07

Reconciliation integrity

CHECK 08

Regression tests

Application Evidence: Admin Dashboard

Financial API
Research demo

Dashboard

Accounts

Journal Entries

Periods

Reports

Audit Logs

Users

Research Evidence

CONNECTED TO HTTP://LOCALHOST:5296

admin

Admin FinanceManager Logout

Dashboard

Live API overview

Refresh

Current user

admin@local.invalid

Accounts loaded

257

Periods loaded

3

Trial balance debit

\$8,480,875.73

Research Evidence

Final report evidence for the live API workflow.

AREA	API COVERAGE	EVIDENCE VALUE
Auth	POST /auth/login and GET /users/me	JWT token, expiry, current user
RBAC	Role-aware navigation	Current roles: Admin, FinanceManager
Accounting	Accounts, journals, periods	CRUD and protected actions
Reports	Trial balance, P/L, balance sheet, ledger	Live financial report endpoints
Audit	GET /audit-logs	Admin/Auditor evidence path

Login screenshot Dashboard screenshot Role-restricted navigation Reports workspace Audit logs Final report insertion

Authenticated Admin and FinanceManager roles with live account, period, and trial-balance values

Application Evidence: Trial Balance

Financial API
Research demo

Dashboard

Accounts

Journal Entries

Periods

Reports

Audit Logs

Users

Research Evidence

CONNECTED TO HTTP://LOCALHOST:5296

admin

Admin

FinanceManager

Logout

Reports Workspace

Generate live financial statements from the selected period and account.

Period

202601

Account

1

Trial balance

Profit/loss

Balance sheet

Account ledger

Total debit

\$8,480,875.73

Total credit

\$8,480,875.73

ACCOUNT CODE	ACCOUNT NAME	TYPE	DEBIT	CREDIT	BALANCE
1000	Cash	Asset	\$442,477.16	\$10.00	\$442,467.16
2000	Accounts Payable	Liability	\$10.00	\$216,446.14	\$216,436.14
3000	Owner Equity	Equity	\$0.00	\$226,031.02	\$226,031.02
4000	Sales Revenue	Revenue	\$0.00	\$215,634.15	\$215,634.15
5000	Operating Expense	Expense	\$215,634.15	\$0.00	\$215,634.15
A001000	Cash - Operating Account	Asset	\$1,524,800.00	\$961,306.92	\$563,493.08

Trial-balance totals and account-level debit, credit, and balance columns

Application Evidence: Auditor Restrictions

Financial API
Research demo

Dashboard

Accounts

Periods

Reports

Audit Logs

Research Evidence

CONNECTED TO HTTP://LOCALHOST:5296
auditor-user

Auditor Logout

Accounts

Search the chart of accounts and inspect current ledger balances.

Search

Search accounts

Account code or name

Read-only access: account maintenance is restricted for this role.

CODE	NAME	TYPE	ACTIVE	LEDGER BALANCE
1000	Cash	Asset	Yes	View balance for 1000
2000	Accounts Payable	Liability	Yes	View balance for 2000
3000	Owner Equity	Equity	Yes	View balance for 3000
4000	Sales Revenue	Revenue	Yes	View balance for 4000
5000	Operating Expense	Expense	Yes	View balance for 5000

Auditor identity, restricted navigation, and explicit read-only account message

Application Evidence: Balanced Journal Lines

Financial API
Research demo

Dashboard

Accounts

Journal Entries

Periods

Reports

Audit Logs

Users

Research Evidence

CONNECTED TO HTTP://LOCALHOST:5296

admin

AdminFinanceManagerLogout

Journal Entries

Review balanced entries and their posting status.

Refresh

Entry amount

25

Create balanced draftBulk create

ID	DATE	REFERENCE	STATUS	DEBIT	CREDIT	DETAIL	ACTIONS
68082	Dec 31, 2026	SEED-D-00008761-202601	Posted	\$690.82	\$690.82	Hide lines for SEED-D-00008761-202601	PostReverseDelete
Journal lines							2 lines
Account 1000 Cash		Description Seed debit line			Line debit \$690.82	Line credit \$0.00	
Account 2000 Accounts Payable		Description Seed credit line			Line debit \$0.00	Line credit \$690.82	
67717	Dec 31, 2026	SEED-D-00008396-202601	Draft	\$687.17	\$687.17	Show lines for SEED-D-00008396-202601	PostReverse

Posted journal entry with equal debit and credit totals and two expanded lines

Contributions

Empirical

Measured Codex 5.4
before/after evidence on one
production-complexity API

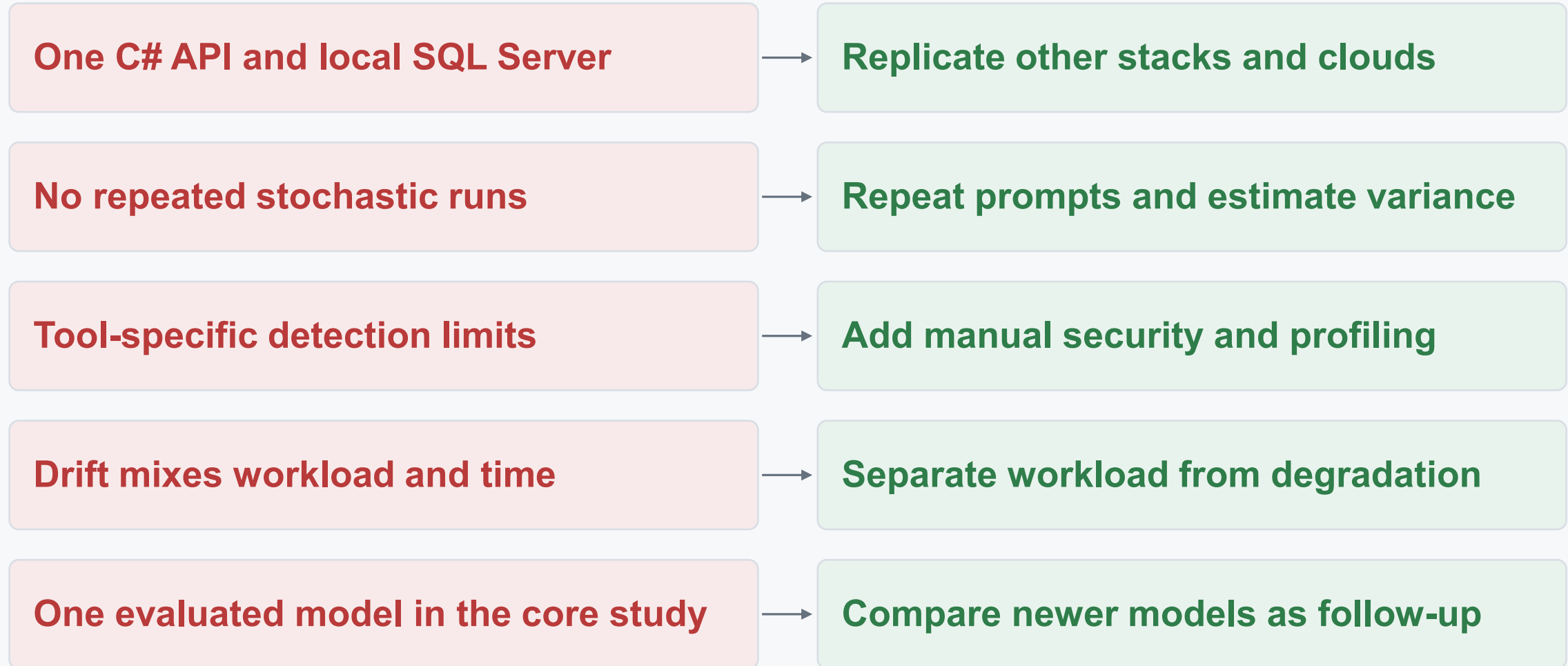
Methodological

Branch-isolated, scanner-
gated acceptance workflow

Practical

Traceable prompts, patches,
tests, screenshots, and tool
outputs

Limitations and Future Work



LIMITATION

NEXT EVIDENCE

Future Work Follow-Up: GPT-5.4 vs GPT-5.5

Supplemental post-thesis future-work evidence

Area	GPT-5.4	GPT-5.5	Reading
SonarQube	0 smells; 74.3%	0 smells; 74.3%	Tie
ZAP	Cleaner residuals	Gate pass; more residuals	GPT-5.4 cleaner
JMeter	Tail wins; p50 regression	Balanced; best spike tail	GPT-5.5 balanced
Patch files	13 / 7 / 13	13 / 4 / 8	GPT-5.5 smaller

Future Work Follow-Up: New-API v2

Supplemental post-thesis future-work evidence

Measure	GPT-5.4	GPT-5.5
Sonar issues	0	0
Coverage	76.2%	74.8%
ZAP verified alerts	12	12
Public tests	152 passed	151 passed
JMeter	No valid candidate	Frozen candidate

Conclusion

1

Measured gains across quality, security, and latency

2

Human review and independent tools remained essential

3

The strongest contribution is the controlled audit-to-fix workflow

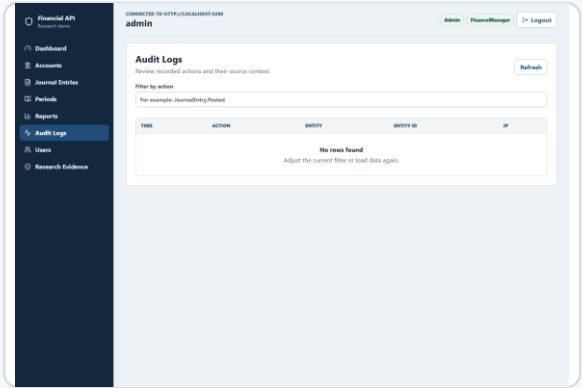
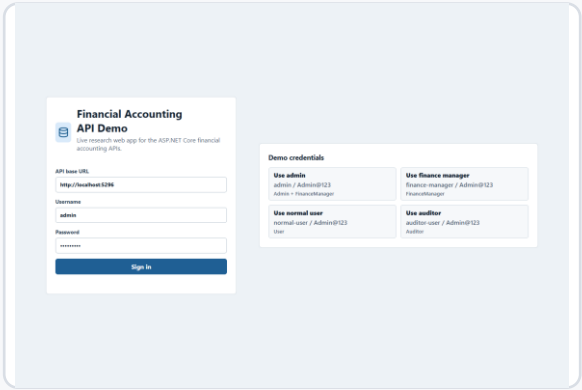
Use the model to propose. Use evidence to decide.

Future Work: Branch and Commit Provenance

Track	Branch	Commit
GPT-5.4 Sonar	baseline-sonarqube-v1	a2279bc
GPT-5.4 ZAP	baseline-zap-v1	5f3bd3c
GPT-5.4 JMeter	baseline-jmeter-v1	78b08b6
GPT-5.5 baseline	codex/gpt-5.5-baseline	ec03403
GPT-5.5 Sonar	codex/gpt-5.5-sonarqube-v1	19763f1
GPT-5.5 ZAP	codex/gpt-5.5-zap-v1	aa1a9bd
GPT-5.5 JMeter	codex/gpt-5.5-jmeter-v1	8d0be3b
Comparison report	codex/gpt-5.5-comparison	d1baa7a

Endpoint and Role Coverage

Endpoint	Admin	Finance	User	Auditor
/auth	Login	Login	Login	Login
/users	Manage/self	Self	Self	Self
/accounts	Manage	Read	Read	Read
/journal-entries	Full	Create/post	Create/read	Read
/periods	Manage/close	Read/close	Read	Read
/reports	Read	Read	-	Read
/audit-logs	Read	-	-	Read



Full SonarQube Metrics

Metric	Baseline	After
Retained findings	28	0
Code smells	21	0
Coverage	74.3%	74.3%
Duplicated lines	0.0%	0.0%
Quality Gate	OK	OK

Full OWASP ZAP Outcomes

Scan	Severity	Before	After
Baseline	Medium	2	0
Baseline	Low	6	0
Baseline	Informational	3	4
Authenticated	Low	3	0
Authenticated	Informational	5	5

Full JMeter Total p95 Results

Profile	Baseline ms	After ms	Reduction
p50	49.45	13.00	73.7%
p100	261.95	34.00	87.0%
p500	176.00	28.00	84.1%
Soak	970.95	56.00	94.2%
Spike	6795.00	1420.00	79.1%

Future Work: Patch Size and Regression Evidence

Track	GPT-5.4 files	GPT-5.5 files	Verification
SonarQube	13	13	0 smells; gate OK
ZAP	7	4	Business gate passed
JMeter	13	8	0% errors; drift gate passed in normalized runs

Future Work: New-API v2 Detailed Results

Measure	GPT-5.4	GPT-5.5
Sonar issues	0	0
Coverage	76.2%	74.8%
Cognitive complexity	340	329
ZAP verified alerts	12	12
Public tests	152 passed	151 passed
JMeter	No valid candidate	Frozen candidate

Threats to Validity

Internal

Branch differences

Tool configuration

Cache and warm-up effects

Construct

Scanner coverage

Metric definitions

Drift heuristic

External

One API

One host

One language and domain

Conclusion

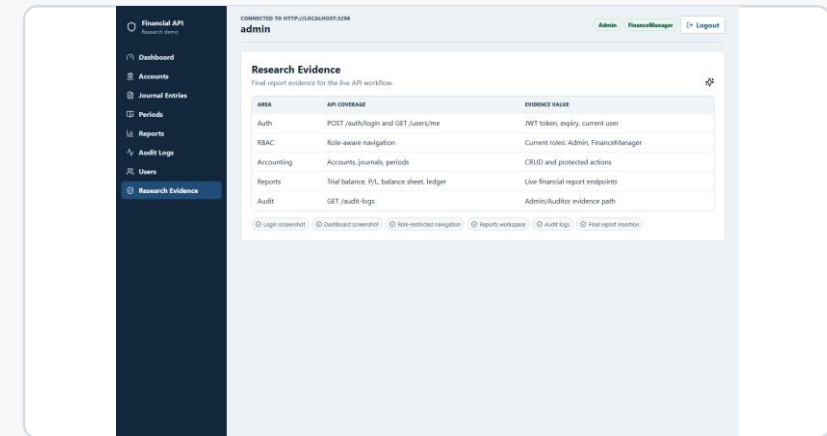
No repeated model runs

Incomplete v2 JMeter pair

Prompt and Human-Effort Traceability



- No suppression
- No weakened test
- No feature deletion
- No unverified acceptance



Selected References

- Hou et al. (2024) - LLMs for software engineering review
- Khoury et al. (2023) - Security of ChatGPT-generated code
- Sandoval et al. (2023) - Security implications of LLM assistants
- Lenarduzzi et al. (2020) - Limits of SonarQube rules
- Zhang et al. (2023) - Web API issues and expectations